Inventario de la Superficie de Ataque

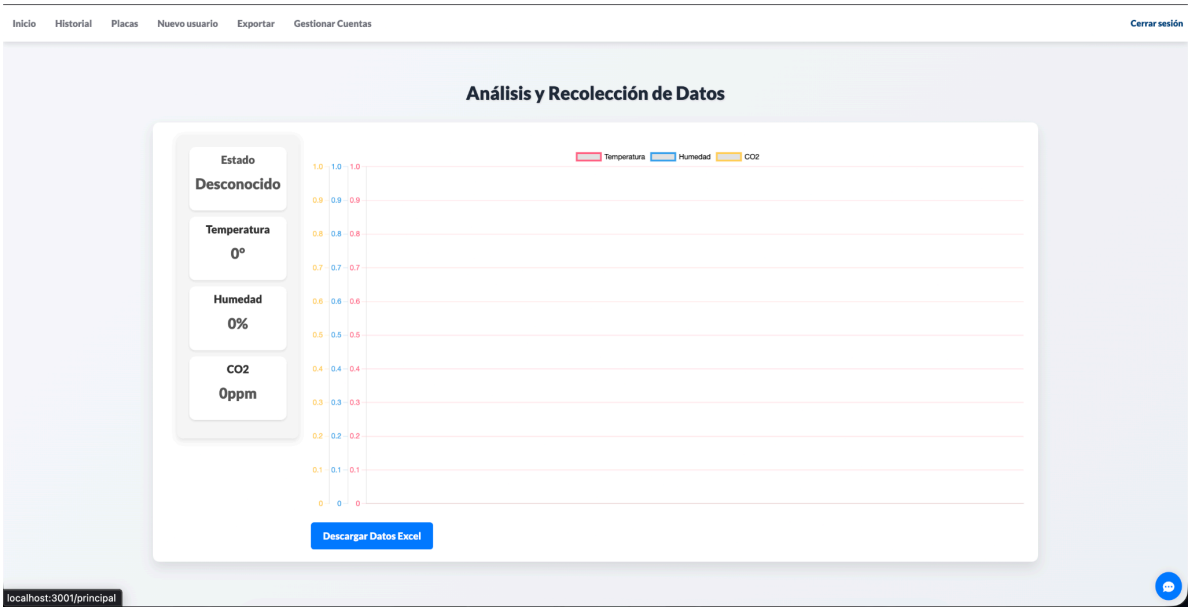
Integrantes: Gabriel Espinoza, Leonardo Peralta, Dalton Maza.

Confirmación de criterios y alcance

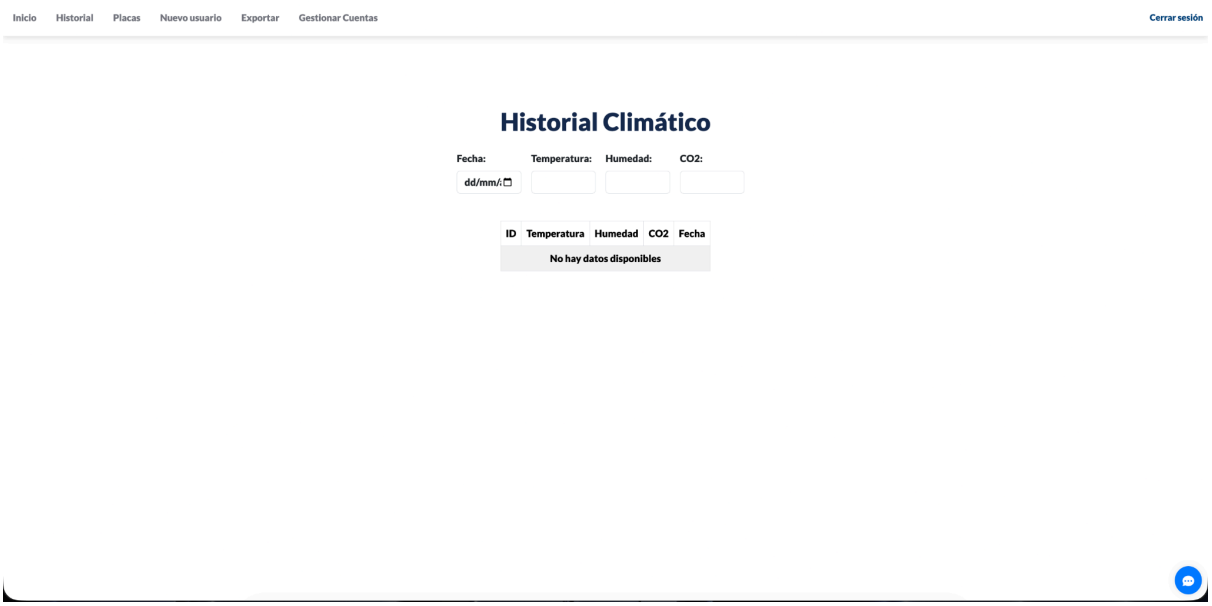
La aplicación cumple con los requisitos mínimos solicitados: código disponible, ejecución local, autenticación y base de datos.

Se probará la seguridad de la aplicación completa, módulos: Inicio de sesión, Gestión de Cuentas, Gestión de Placas, Descarga de Datos Excel, Historial, Recolección de datos (backend).

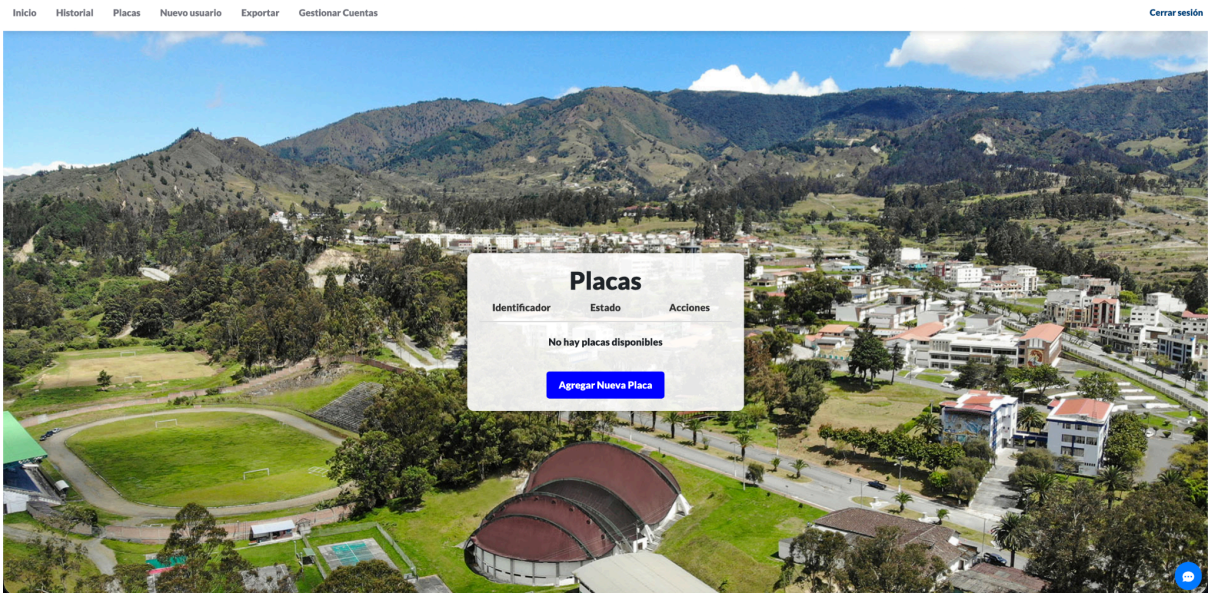
Inventario de ataque



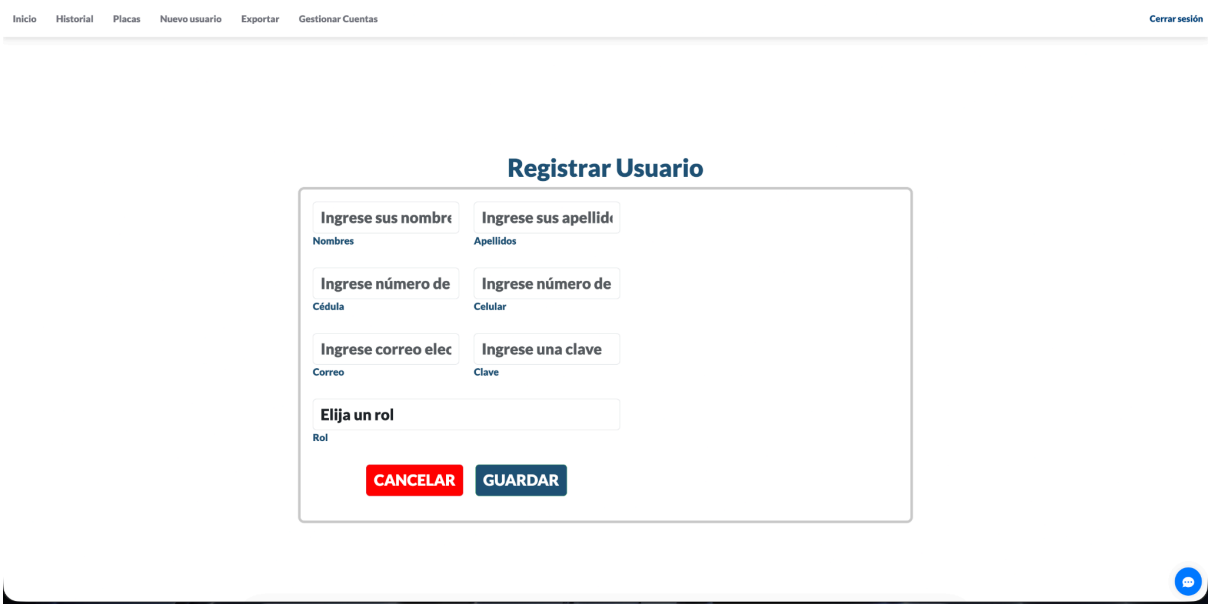
Pagina / Ruta	/principal (src/app/principal/page.jsx)
Titulo visible	**Analisis y Recolección de Datos**
Acceso requerido	Usuario autenticado (JWT en contexto AuthContext)
Endpoints	GET /data/all (últimas lecturas) GET /data (serie para gráfica) GET /weatherState (estado: BUENO/REGULAR/PELIGROSO)
Funcionalidad	Visualización en tiempo real de temperatura, humedad, CO_2 y estado del clima; exportación de datos a Excel
Riesgo existente	Consultas sin autenticación observables en red (token solo condiciona el botón, no las peticiones); consumo continuo de la API habilita DoS por agotamiento



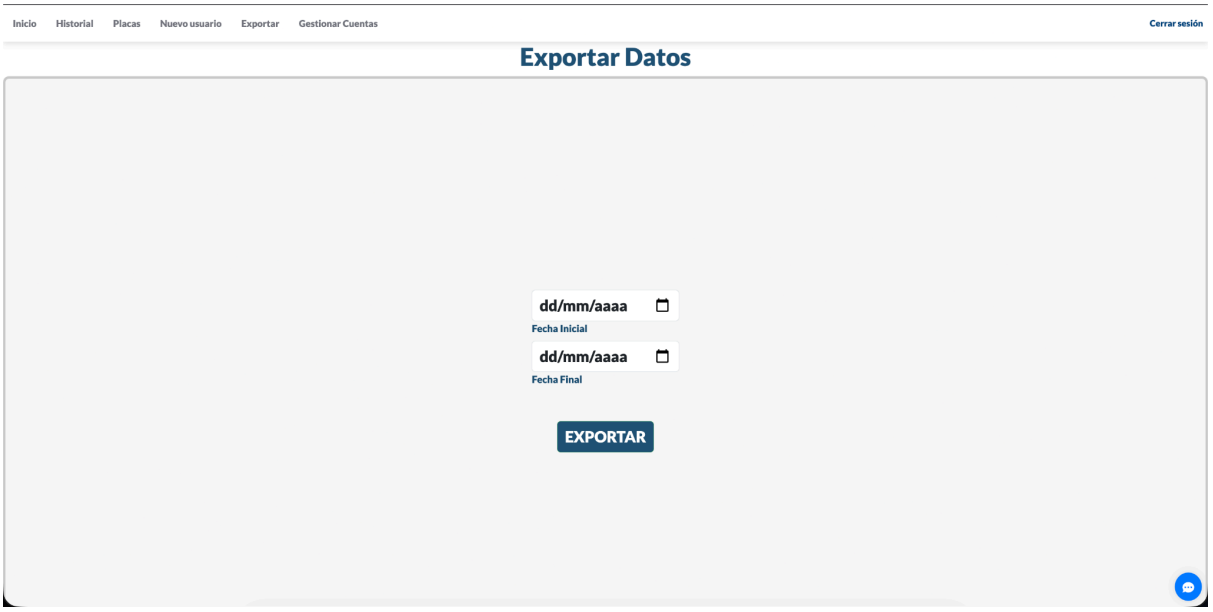
Pagina / Ruta	/historial (src/app/historial/page.jsx)
Titulo visible	**Historial Climático**
Acceso requerido	Usuario autenticado
Fomulario	fecha (date) temperatura (number) humedad (number) co2 (number) — filtrado en el cliente sobre el dataset completo
Endpoints	GET /data (servicio getAllHistorial, carga todo el histórico sin paginación de servidor)
Funcionalidad	Tabla paginada (50 ítems/página) de registros históricos: ID, temperatura, humedad, CO_2, fecha
Riesgo existente	Exposición de la totalidad del histórico en una sola respuesta (fuga de datos masiva y consumo de memoria/DoS con colecciones grandes)



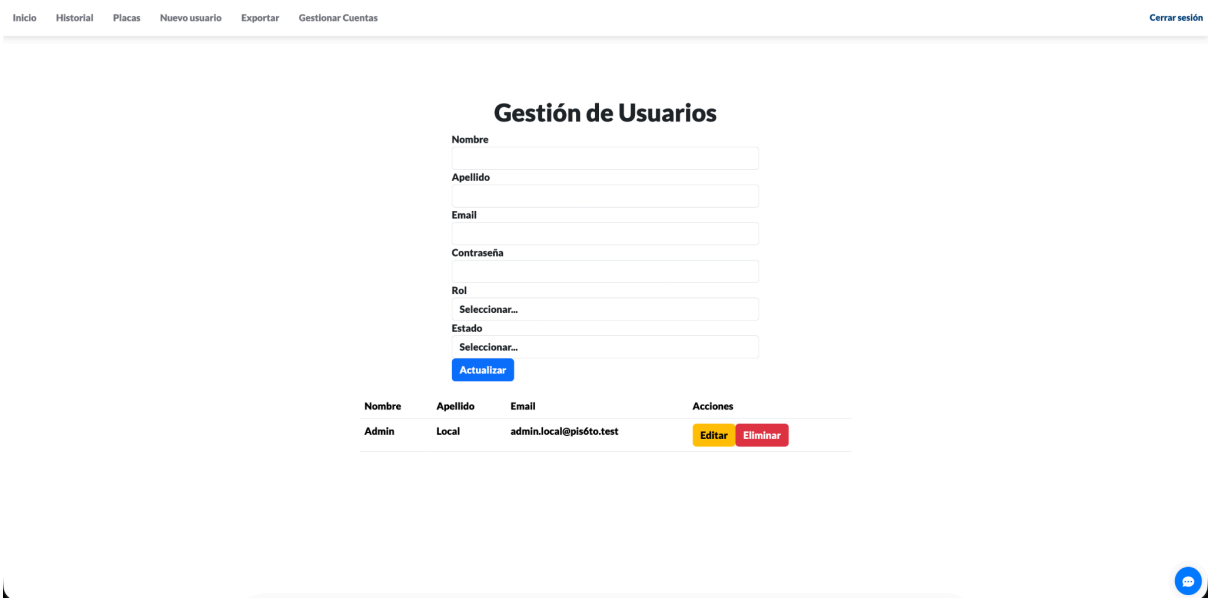
Pagina / Ruta	/placas (src/app/placas/page.jsx)
Titulo visible	Placas
Acceso requerido	Administrador (gestión de inventario)
Formularios	Modal "Registrar/Editar Placa": identificador (texto, obligatorio) estado (select: Activa / Inactiva, obligatorio)
Endpoints	GET /Placa (listar) POST /Placa (crear) PUT /Placa/{_id} (editar) · DELETE /Placa/{_id} (eliminar)
Funcionalidad	CRUD completo del inventario de placas (hardware) con botones de editar/eliminar por fila
Riesgo existente	Operaciones de escritura/borrado sin evidencia de política isAdmin en el front (depende 100 % del back-end) identificadores MongoDB expuestos en el cliente facilitan IDOR



Pagina / Ruta	/crear_usuario (src/app/crear_usuario/page.jsx)
Titulo visible	Registrar Usuario
Acceso requerido	Administrador (creación de cuentas)
Endpoints	nombres (texto) apellidos (texto) cédula (texto) celular (texto) correo (email) clave (password) rol (select: Admin / User) — validación solo de cliente con yup + react-hook-form
Funcionalidad	Captura de datos personales (PII: cédula, celular, correo) y asignación de rol — incluido Admin — desde el formulario
Riesgo existente	(a) Validación solo en el cliente = evitable por manipulación de request; (b) si el endpoint real subyacente (POST /auth/register o /account) no exige admin en el servidor, permite auto-registro con privilegios (c) la funcionalidad parece incompleta (sin envío), lo cual es un hallazgo funcional de calidad también reportable



Pagina / Ruta	/exportar (src/app/exportar/page.jsx)
Titulo visible	Exportar Datos
Acceso requerido	Usuario autenticado
Formularios	startDate (date, obligatorio) endDate (date, obligatorio) — validación de cliente con yup
Endpoints	POST /data/export — body: { startDate, endDate } (ISO) respuesta binaria xlsx descargada como exported_data.xlsx (js-file-download)
Funcionalidad	Generación y descarga de reportes Excel del histórico climático por rango de fechas
Riesgo existente	ndpoint de extracción masiva: sin rate limiting ni verificación de autorización visible, permite descargar toda la telemetría en bloque (fuga de datos / A01)



Pagina / Ruta	/cuentas (src/app/cuentas/page.jsx)
Titulo visible	Gestion de usuarios
Acceso requerido	Administrador
Endpoints	name (3–25) · lastname (3–25) email password (8–30, campo visible en edición) role (select cargado desde GET /role) state (select: ACTIVA / BLOQUEADA / INACTIVA) — validación yup de cliente
Funcionalidad	Listado completo de cuentas (nombre, apellido, email) y edición de datos personales, contraseña, rol y estado
Riesgo existente	(a) El id objetivo se toma del localStorage manipulable por el usuario → IDOR trivial si el back-end no valida propiedad/rol (A01) (b) el campo contraseña en edición puede facilitar el cambio no autorizado de credenciales ajenas (c) import de mongoose en el front-end para validar ObjectId (mala práctica, expone lógica interna)